

Programa IMPACT#include13

Trabajo de Final de Curso

Anna Martínez Pulido

ID Scola: Ex-1160

7 de junio de 2026

Índice

Índice.....	1
Fase 1 - Diseño del asistente.....	2
Problema y usuario.....	2
Tecnologías elegidas.....	2
Flujo de las 4 capacidades.....	2
Diagrama.....	3
Fase 2 - Base de conocimiento (RAG).....	4
Fase 3 - Construcción del asistente +	
Fase 4 - Demostración y entrega.....	6
Capacidad 1: Análisis de políticas.....	6
Capacidad 2: Elaboración de un gap analysis.....	7
Capacidad 3: Respuesta a preguntas de auditoría.....	9
Capacidad 4: Propuestas de mejora.....	10
Reflexión final.....	11

Fase 1 - Diseño del asistente

Problema y usuario

MIDTECH necesita analizar políticas de seguridad y detectar incumplimientos normativos automáticamente. Con ese objetivo, se realizará un asistente de ciberseguridad y compliance. El usuario objetivo es el trabajador encargado de la cumplimentación de la normativa y el posible auditor.

Tecnologías elegidas

LLM	Gemini: Por su facilidad de uso para usuarios principiantes y su razonamiento avanzado. Además la suscripción de Google One para Google Drive incluye el plan de Gemini.
Orquestación	n8n: Mejor integración con Gemini que Make, muy visual, más común en entornos profesionales.
Gestor documental	Google Drive: Experiencia previa con las herramientas de Google.

Flujo de las 4 capacidades

1. Análisis de políticas

Entrada: el usuario envía el mensaje “Analiza la política de MIDTECH” junto al documento.

Proceso: n8n analiza el documento, lo divide en fragmentos, busca en el RAG los fragmentos más relevantes y los envía al LLM con el prompt de sistema.

Salida: Informe de análisis con tres secciones diferenciadas (áreas cubiertas, nivel de cobertura y áreas ausentes).

2. Detección de riesgos

Entrada: el usuario envía el mensaje “realiza un gap analysis de riesgos e incumplimientos” junto al documento de política de MIDTECH.

Proceso: n8n recupera los documentos desde Google Drive, lo divide en fragmentos, busca en el RAG los fragmentos más relevantes y los envía al LLM con el prompt de sistema.

Salida: Gap analysis con una entrada por cada incumplimiento.

3. Respuesta a preguntas de auditoría

Entrada: el usuario envía preguntas de auditoría al chatbot junto al documento de política de MIDTECH.

Proceso: n8n recupera los documentos desde Google Drive, lo divide en fragmentos, busca en el RAG los fragmentos más relevantes y los envía al LLM con el prompt de sistema.

Salida: Respuesta citando la política vs la normativa.

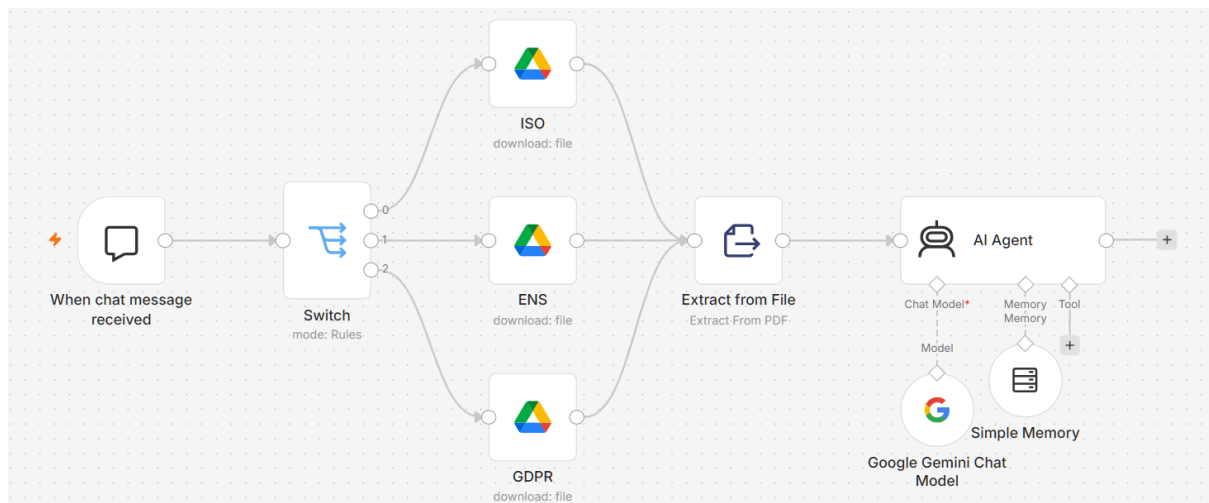
4. Propuestas de mejora

Entrada: el usuario envía el mensaje “realiza una lista de propuestas de mejora” junto al documento de política de MIDTECH.

Proceso: n8n recupera los documentos desde Google Drive, lo divide en fragmentos, busca en el RAG los fragmentos más relevantes y los envía al LLM con el prompt de sistema.

Salida: Lista ordenada por prioridad.

Diagrama

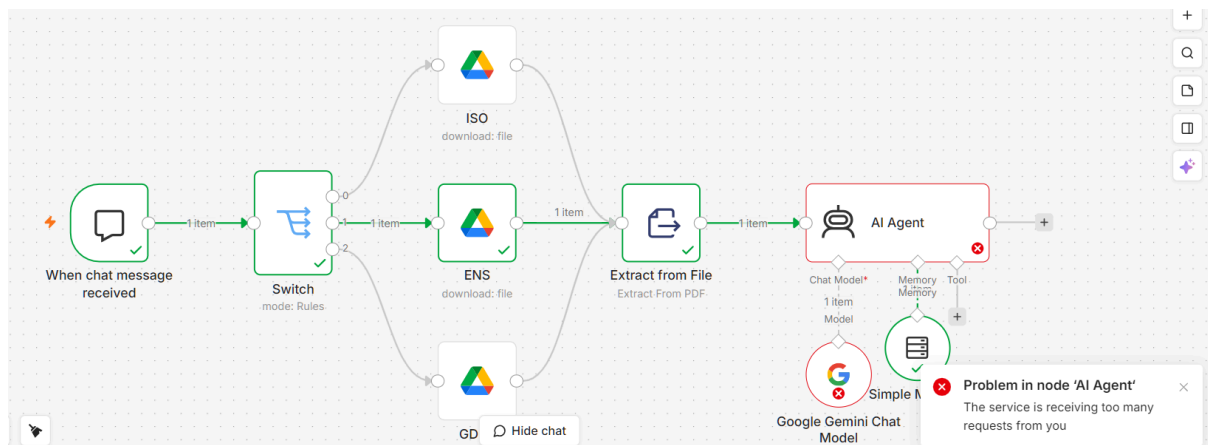


Fase 2 - Base de conocimiento (RAG)

Pese a inicialmente haber funcionado, eventualmente siempre me he acabado topando con problemas que han impedido la construcción de un RAG y de un agente funcional.

Tras la sesión de dudas se propuso crearlo a partir de Gems de Gemini, lo cual parecía una solución, pero también acabé encontrándome con que no es posible la integración de los Gems a n8n o a ningún otro programario de workflows.

Esta es la situación actual al intentar procesar una consulta:



Mientras que la respuesta proporcionada a través del Gem de Gemini es la siguiente:

¿Qué dice el GDPR sobre las medidas técnicas de seguridad?

Capacidad 3 — Respuesta a preguntas de auditoría · Gem personalitzat

Respuesta

El GDPR exige que tanto el responsable como el encargado del tratamiento implementen medidas técnicas y organizativas apropiadas para garantizar un nivel de seguridad adecuado frente a los riesgos detectados. Entre estas medidas, menciona explícitamente la seudonimización y el cifrado de datos personales, la garantía de confidencialidad, integridad, disponibilidad y resiliencia de los sistemas, así como la capacidad de restaurar el acceso a los datos de forma rápida en caso de incidentes. PDF +1

Evidencia en Política MIDTECH

No se ha encontrado evidencia suficiente en la documentación proporcionada.

Referencia Normativa

La normativa establece que: "Teniendo en cuenta el estado de la técnica, los costes de aplicación, y la naturaleza, el alcance, el contexto y los fines del tratamiento, así como riesgos de probabilidad y gravedad variables para los derechos y libertades de las personas físicas, el responsable y el encargado del tratamiento aplicarán medidas técnicas y organizativas apropiadas para garantizar un nivel de seguridad adecuado al riesgo [...]".

Estándar exacto: Artículo 32 (Seguridad del tratamiento) del Reglamento (UE) 2016/679 (GDPR / RGPD). PDF +1

Consulta introducida: “¿Qué dice el GDPR sobre las medidas técnicas de seguridad?”

Respuesta: “El GDPR exige que tanto el responsable como el encargado del tratamiento implementen medidas técnicas y organizativas apropiadas para garantizar un nivel de seguridad adecuado frente a los riesgos detectados. Entre estas medidas, menciona explícitamente la seudonimización y el cifrado de datos personales, la garantía de confidencialidad, integridad, disponibilidad y resiliencia de los sistemas, así como la capacidad de restaurar el acceso a los datos de forma rápida en caso de incidentes.

Referencia Normativa: La normativa establece que: "Teniendo en cuenta el estado de la técnica, los costes de aplicación, y la naturaleza, el alcance, el contexto y los fines del tratamiento, así como riesgos de probabilidad y gravedad variables para los derechos y libertades de las personas físicas, el responsable y el encargado del tratamiento aplicarán medidas técnicas y organizativas apropiadas para garantizar un nivel de seguridad adecuado al riesgo [...]". Estándar exacto: Artículo 32 (Seguridad del tratamiento) del Reglamento (UE) 2016/679 (GDPR / RGPD)."

The screenshot shows a chatbot interface with a dark background. In the top right corner, there is a menu with the following items: PDF, MIDTECH - Política, and Seguridad PSI. The main chat area contains a question in a light blue bubble: "¿Qué dice la política de MIDTECH respecto a los accesos remotos?". Below this, the chatbot's response is displayed in white text: "La política de MIDTECH establece lo siguiente respecto a los accesos remotos:". This is followed by two bullet points, each preceded by a small circle icon. The first bullet point is "El acceso remoto a los sistemas corporativos debe realizarse mediante una VPN corporativa." and the second is "Los usuarios que accedan de forma remota deben utilizar equipos corporativos o dispositivos que estén aprobados por el departamento de TI." Both bullet points have a small "PDF" link next to them.

PDF
MIDTECH -
Política
Seguridad PSI

¿Qué dice la política de MIDTECH respecto a los accesos remotos?

La política de MIDTECH establece lo siguiente respecto a los accesos remotos:

- El acceso remoto a los sistemas corporativos debe realizarse mediante una VPN corporativa. PDF
- Los usuarios que accedan de forma remota deben utilizar equipos corporativos o dispositivos que estén aprobados por el departamento de TI. PDF

Consulta introducida: “¿Qué dice la política de MIDTECH respecto a los accesos remotos?”

Respuesta: “La política de MIDTECH establece lo siguiente respecto a los accesos remotos:

- El acceso remoto a los sistemas corporativos debe realizarse mediante una VPN corporativa.
- Los usuarios que accedan de forma remota deben utilizar equipos corporativos o dispositivos que estén aprobados por el departamento de TI.”

Fase 3 - Construcción del asistente +

Fase 4 - Demostración y entrega

Volviendo a partir de que no he logrado que el asistente sea funcional a partir de los Gems realizados con Gemini, y de que las consultas me dan error por exceso de intentos, solo puedo proporcionar evidencia a partir de Gemini.

Capacidad 1: Análisis de políticas

TFC · Gem personalitzat

Informe de Análisis de Política de Seguridad

1. Áreas de seguridad cubiertas

A continuación, se detalla el análisis de los distintos ámbitos tratados en la Política de Seguridad de la Información (PSI) de MIDTECH S.A.

- **Área analizada:** Control de acceso y gestión de usuarios
 - **Evidencia encontrada:** El acceso se rige por el principio de mínimo privilegio y requiere autorización previa. Las cuentas inactivas por más de 90 días se desactivan de forma automática. PDF +3
 - **Evaluación breve:** Cobertura de nivel básico. Existen lineamientos lógicos, pero la política carece de revisiones periódicas formales documentadas. PDF
- **Área analizada:** Gestión de contraseñas
 - **Evidencia encontrada:** Se exige una longitud mínima de 8 caracteres, combinación alfanumérica y cambio cada 180 días, impidiendo la reutilización de las últimas 5 contraseñas. PDF
 - **Evaluación breve:** Cobertura parcial. Establece controles tradicionales, pero omite la autenticación multifactor (MFA), la cual se encuentra "en evaluación". PDF
- **Área analizada:** Seguridad física y del entorno
 - **Evidencia encontrada:** La sede de Zaragoza tiene control de acceso mediante tarjeta y un Centro de Proceso de Datos (CPD) con climatización y sistemas contra incendios. El acceso al CPD está restringido al personal de TI. PDF +1

Respuesta completa:  Informe de Análisis de Política de Seguridad

Capacidad 2: Elaboración de un gap analysis.

¿Cumplimos con el artículo 32 del GDPR?

Capacidad 2 — Detección de riesgos e incumplimientos · Gem personalitzat

Como auditor senior de ciberseguridad y cumplimiento normativo, presento a continuación el GAP Analysis centrado en el nivel de cumplimiento de la Política de Seguridad de la Información de MIDTECH S.A. respecto a los requisitos explícitos del artículo 32 del Reglamento General de Protección de Datos (GDPR).

Área normativa	Carencia detectada	Criticidad	Referencia normativa
Protección de datos en tránsito	La política de MIDTECH no documenta de forma formal el cifrado de la información en tránsito ni exige protocolos seguros mínimos (como TLS 1.2 o superior) para las comunicaciones corporativas. Esta omisión vulnera la exigencia de aplicar medidas de seudonimización y cifrado de los datos personales. PDF +1	Alto	GDPR Art. 32.1(a)
Continuidad de negocio	La organización carece de un Plan de Continuidad de Negocio (BCP) y de un Plan de Recuperación ante Desastres (DRP) formalmente documentados . Esta carencia contraviene la obligación legal de garantizar la resiliencia y disponibilidad permanentes de los sistemas y servicios de tratamiento. PDF +1	Alto	GDPR Art. 32.1(b)

Copias de seguridad	Las copias de respaldo se almacenan en la misma ubicación física que los sistemas de producción (CPD de Zaragoza), sin copia externa (offsite), y no se ejecutan pruebas periódicas de restauración. Esto imposibilita asegurar la capacidad de restaurar rápidamente la disponibilidad y el acceso a los datos personales en caso de incidente físico o técnico. PDF +1	Alto	GDPR Art. 32.1(c)
Revisión y cumplimiento	No existe un proceso de auditoría interna para evaluar el cumplimiento de la política, ni hay constancia documental de su última revisión formal. Esta debilidad incumple el requisito de mantener un proceso de verificación, evaluación y valoración regulares de la eficacia de las medidas técnicas y organizativas. PDF +1	Medio	GDPR Art. 32.1(d)
Gestión de incidentes	El procedimiento básico de incidentes no estipula la realización de simulacros o pruebas periódicas de respuesta. Esto vulnera la obligación de probar y evaluar regularmente los procedimientos destinados a garantizar la seguridad del tratamiento. PDF +1	Medio	GDPR Art. 32.1(d)

Seguridad física	Los servidores locales de las sedes de Madrid y Barcelona no cuentan con el mismo nivel de control físico y ambiental que el CPD principal, y no existe un procedimiento documentado de inspecciones periódicas de estas instalaciones. Esto incrementa la probabilidad de destrucción, pérdida o acceso no autorizado accidental o ilícito a los datos personales. PDF +1	Medio	GDPR Art. 32.2
Control de accesos	No se ha implementado la autenticación multifactor (MFA) de forma generalizada y la política permite el uso de contraseñas con una longitud mínima de apenas 8 caracteres. Estas debilidades evidencian un nivel de seguridad inadecuado respecto a los riesgos de comunicación o acceso no autorizados a los datos personales. PDF +1	Alto	GDPR Art. 32.2
Concienciación y formación	No se dispone de un plan de formación continua en ciberseguridad, no hay registros formales de qué empleados completaron el proceso inicial, y no se realizan ejercicios prácticos (ej. simulaciones de phishing). Esta carencia no ofrece garantías de que las personas bajo la autoridad del responsable traten los datos personales de acuerdo con las instrucciones de seguridad emitidas. PDF +1	Medio	GDPR Art. 32.4

Capacidad 3: Respuesta a preguntas de auditoría

¿Se ejecutan análisis de vulnerabilidades de rutina y se corrigen los fallos detectados en plazos breves?

Capacidad 3 — Respuesta a preguntas de auditoría · Gem personalitzat

Respuesta

No. Según la documentación aportada, no hay ninguna directriz establecida sobre la ejecución rutinaria de análisis de vulnerabilidades ni sobre un proceso de gestión de parches para corregir los fallos detectados.

Evidencia en Política MIDTECH

No se ha encontrado evidencia suficiente en la documentación proporcionada. Tras revisar íntegramente la Política de Seguridad de la Información (PSI-MIDTECH-2025-v2.1), no se menciona en ninguno de sus apartados, ni en el Anexo A de controles implementados, la existencia de escaneos de vulnerabilidades, pruebas de penetración (pentesting) o políticas de aplicación de parches. [PDF](#)

Referencia Normativa

La normativa establece que: "La información sobre vulnerabilidades técnicas de los sistemas de información en uso debe obtenerse, la exposición de la organización a tales vulnerabilidades debe evaluarse y se deben tomar las medidas apropiadas" (ISO/IEC 27001:2022, Anexo A, Control 8.8 - *Management of technical vulnerabilities*).

Adicionalmente, el Esquema Nacional de Seguridad (ENS, Real Decreto 311/2022) exige en su Artículo 21 mantener la integridad y actualización del sistema mediante la gestión oportuna de vulnerabilidades. [PDF](#)

Evaluación Comparativa

No evidenciado. La política de MIDTECH no cubre el tema preguntado y omite por completo los controles de seguridad proactiva orientados a descubrir y mitigar vulnerabilidades técnicas. Esto representa un vacío importante en la estrategia de prevención frente a las exigencias normativas aplicables (ISO 27001 y ENS).

Capacidad 4: Propuestas de mejora

Capacidad 4 — Propuestas de mejora · Gem personalitzat

Propuestas de Mejora — Política de Seguridad MIDTECH

Resumen Ejecutivo

- **Principales debilidades detectadas:** Tras el análisis de la Política de Seguridad de la Información (PSI) de MIDTECH S.A., se han identificado brechas críticas en la continuidad del negocio al carecer de un Plan de Continuidad de Negocio (BCP) y copias de seguridad externas. PDF +1
- **Áreas prioritarias:** Existen deficiencias significativas en el cumplimiento del GDPR, como la ausencia de un Delegado de Protección de Datos (DPO) y la falta de Evaluación de Impacto (EIPD). PDF +2
- **Nivel general de madurez:** El nivel de madurez actual de la organización es básico-intermedio; si bien existen controles técnicos fundamentales implementados (como el cifrado en reposo o inventarios manuales), carecen de formalización documental, pruebas periódicas y un enfoque de mejora continua. PDF +3
- **Enfoque recomendado de remediación:** Se recomienda un enfoque basado en el riesgo, priorizando la corrección de incumplimientos normativos severos (GDPR) y salvaguardas de disponibilidad técnica (backups *offsite* y MFA), para posteriormente robustecer la documentación corporativa y la resiliencia operativa.

Tabla Priorizada de Mejoras

ID	Mejora Propuesta	Problema Detectado	Justificación Normativa
----	------------------	--------------------	-------------------------

Respuesta completa: [Propuestas de Mejora — Política de Seguridad MIDTECH](#)

Reflexión final

La realización de este trabajo de fin de curso ha supuesto un reto importante que, aunque no ha alcanzado los resultados esperados, me ha permitido adquirir conocimientos y experiencias valiosas. Durante el desarrollo del proyecto surgieron diferentes dificultades técnicas (principalmente con n8n) y de planificación que afectaron al resultado final y que evidenciaron algunas carencias en la gestión del tiempo y la definición de objetivos.

He comprendido la necesidad de profundizar en determinadas tecnologías y herramientas antes de abordar desarrollos complejos, ya que una curva de aprendizaje más pronunciada de la prevista puede comprometer significativamente los plazos establecidos, como se ha dado el caso en esta ocasión.

A pesar de las dificultades encontradas y de que el resultado final no ha sido el deseado, considero que el proceso ha sido enriquecedor desde el punto de vista formativo. Los errores cometidos han permitido identificar áreas de mejora tanto técnicas como metodológicas.